

Enterprise AI Threat Model: Autonomous RAG Executive Assistant

System Target	Autonomous RAG-Powered AI Executive Assistant
Integrations	Google Drive, OneDrive, Enterprise Email, Financial/Operational APIs
Risk Profile	High (Handles Confidential Documents, PII, and Financial Transactions)
Primary Frameworks	MITRE ATLAS

Surface 1: Input & Prompt Surface

Threat Scenario 1.1: Direct Jailbreak & Safety Guardrail Bypass

- **Vector:** Attacker uses cognitive overload, persona adoption, or multi-turn deception prompts to bypass safety alignment, forcing the system to execute unauthorized operational commands (e.g., mass-deleting calendar events).
- **Vulnerability:** System relies solely on standard system-prompt instructions without independent input safety classifiers or rate-limiting.
- **MITRE ATLAS Mapping:** AML.T0054 (LLM Jailbreak)
- **Target Impact:** High operational disruption, scheduling chaos, loss of operational continuity.

Threat Scenario 1.2: Indirect Prompt Injection via RAG Sources

- **Vector:** Attacker hides adversarial instructions within a benign-looking document uploaded to Google Drive/OneDrive or embedded in an incoming email. When the RAG pipeline retrieves this chunk, the model executes the embedded payload.
- **Vulnerability:** Ingestion engine treats retrieved context as trusted input without separating data content from instruction channels.
- **MITRE ATLAS Mapping:** AML.T0051 (LLM Prompt Injection: Indirect)
- **Target Impact:** System hijacking, unauthorized document summaries leaking sensitive context, indirect operational execution.

Surface 2: Data & Retrieval Surface (Knowledge Base & Pipeline)

Threat Scenario 2.1: RAG Knowledge Base Poisoning

- **Vector:** Attacker with write access to shared drives uploads manipulated documents containing biased, toxic, or fraudulent information (e.g., altering vendor payment account details).
- **Vulnerability:** Absence of strict access controls, document validation, or cryptographic integrity checks on files ingested into the vector database.
- **MITRE ATLAS Mapping:** AML.T0020 (Poison Training Data / RAG Knowledge Base)
- **Target Impact:** Fraudulent financial disbursements, corrupted business decision-making, reputational damage.

Threat Scenario 2.2: Data Pipeline & Development Workspace Tampering

- **Vector:** Malicious insider or compromised account modifies data cleansing scripts or alters dataset embeddings during exploratory analysis in Jupyter notebooks.
- **Vulnerability:** Inadequate insider threat monitoring, lack of version-controlled pipeline immutability, and broken data provenance tracking.
- **MITRE ATLAS Mapping:** AML.T0010 (ML Supply Chain Compromise)
- **Target Impact:** Silent introduce of systemic bias, model degradation, and unauthorized logic shifts in production workflows.

Surface 3: Model & Logic Surface

Threat Scenario 3.1: Model Extraction / Parameter Discovery

- **Vector:** Attacker queries the RAG system systematically with automated inputs to map output confidence scores and reconstruct underlying system prompts, model parameters, or RAG architecture.
- **Vulnerability:** Lack of API rate-limiting, missing anomaly detection for systematic query patterns, and verbosity in system error handling.
- **MITRE ATLAS Mapping:** AML.T0024 (Exfiltration via Model Inversion / Extraction)
- **Target Impact:** Intellectual property loss, exposure of system architecture enabling highly targeted follow-on attacks.

Threat Scenario 3.2: Membership Inference & Training Data Reconnaissance

- **Vector:** Attacker inputs specific target queries to determine whether particular sensitive files, individual PII, or proprietary records exist within the training or RAG index.

- **Vulnerability:** Absence of privacy-preserving noise mechanisms (e.g., Differential Privacy) and lack of output redaction for non-authorized users.
- **MITRE ATLAS Mapping:** AML.T0008 (Data Reconstruction / Membership Inference)
- **Target Impact:** Regulatory non-compliance (GDPR / CCPA fines), breach of confidentiality, targeted spear-phishing using leaked presence data.

Surface 4: Output & Agency Surface (System Integration & Actions)

Threat Scenario 4.1: Unauthorized External Exfiltration & Communication

- **Vector:** Adversarial input triggers the assistant to draft and automatically dispatch emails containing confidential company information to external domains.
- **Vulnerability:** Direct API execution privileges without Human-in-the-Loop (HITL) review, absence of domain-locking, and missing outbound DLP filters.
- **MITRE ATLAS Mapping:** AML.T0048 (Exfiltration via LLM Output)
- **Target Impact:** Enterprise data breach, loss of competitive advantage, severe reputational and legal liability.

Threat Scenario 4.2: Automated Financial Fraud via Over-Privileged Agency

- **Vector:** A two-stage attack where poisoned RAG data alters bank routing information, followed by an indirect prompt forcing the assistant to execute automated payment workflows.
- **Vulnerability:** Over-provisioned API credentials, lack of transaction threshold caps, absence of destination-account whitelist validation, and zero HITL authorization for financial execution.
- **MITRE ATLAS Mapping:** AML.T0040 (ML-Enabled Autonomous Action Exploitation)
- **Target Impact:** Direct, large-scale financial loss, fraud liability, enterprise operational disruption.

Governance & Engineering Mitigation Control Blueprint

To address the identified threat surfaces, the following mandatory controls must be implemented across the architecture:

Required Mitigation Matrix	
Control Tier	Technical & Governance Controls

Pre-Inference (Input Controls)	• Dual-LLM pattern separating Data from Instruction • Upstream Guardrail Classifier (Detecting Jailbreak/Injection) • Strict API Rate-Limiting & Query Pattern Anomaly Detection
Data & RAG (Pipeline Controls)	• RBAC Enforcement on Vector DB Retrieval (User-Level Scope) • Cryptographic Hash Verification for File Ingestion • Automated PII Redaction & Data Provenance Logging
Execution & Agency (Output Controls)	• Mandatory HITL for Financial Execution > \$0 / Emails • Transaction Bounds & Approved Vendor Whitelist Verification • Outbound Data Loss Prevention (DLP) Stream Filter